Focused test plan and requirement traceability

Verify that the analyst can read reports, the engineer can read maintenance instructions and unassigned users are denied. The ten tests also verify restricted administration, network isolation, remote access and application recovery for the assignment.

All operational tests are NOT TESTED. Actual results and evidence fields are blank. The architecture defines the approved topology and flows. The security requirements define the controls.

1. Test governance and evidence

Obtain stage approvals before lab action. Phase 5 active requests and temporary changes need K and applicable control approvals. Fix the lab source, target, versions, synthetic identity, action and rate, expected result, evidence ID, second observation, stop condition and rollback. Observe home and production passively. Active checks use approved lab-owned targets only.

Record all 91 mandatory subchecks in **Test Cases** in Deliverable 03. Keep exact IDs, preconditions, scope, this plan's expected result, actual result, operator, time, evidence and second observation. Before network denials, verify a working allowed control on the known-listening lab service. Match denials to the effective rule, grant or role and its log, counter or device evidence. Use FWT-04 for local privileges and FWT-05 for certificate trust. A failed connection or login alone proves no policy decision. Keep results, failures, rollback and retests private under the evidence conventions.

Mark a child **PASS** only when the result and required evidence are verified. Mark an observed mismatch **FAIL**. Blocked, unperformed or unverified checks are **NOT TESTED**. The overall test passes only when all its mandatory children pass. It fails if any child fails and otherwise stays NOT TESTED. NOT APPLICABLE cannot waive a mandatory check. A critical safety failure blocks acceptance regardless of score. Record owner user acceptance testing (UAT) separately from engineering verification.

1.1. FWT-01 - Isolation and readiness

Scope: FWR-01; FSC-01; FAC-01. Critical. Approval A and the relevant network/egress stage.

Objective and method: Verify the prepared equipment, ownership, compatibility, existing data and services, original Windows disk protection, backups and both consoles. Verify exact approval before any destructive work. Trace the cables, TP-Link TL-SG108E switch separation, Dell Proxmox bridges and workload network interfaces (NICs) to physical HP OPNsense. Compare IPv4 and IPv6 routes and forwarding, private protected aliases, extra adapters, Wi-Fi, virtual private networks (VPNs) and automatic routes with the isolation checklist. Check for trust, synchronization, credential or data reuse. Keep the GL.iNet Beryl AX uplink disconnected until independent isolation, scoped egress and rollback are approved. With a working allowed control, make the single approved request to a known-listening lab-owned mock boundary.

Expected result and pass/fail criteria: No unapproved protected path or integration. The intended control denies the mock request. Keep all test traffic off home and production networks.

Second observation: Compare inventory with the physical and firmware views. A security PASS requires cable and policy inspection plus the allowed control, mock denial and matching effective HP rule and log or counter. On unexpected connectivity, stop and verify console isolation and rollback.

Record	Value
Actual result	
Evidence reference	
Operator / date / version	
Verdict	NOT TESTED

1.2. FWT-02 - Three-zone network and administration

Scope: FWR-02; FSC-02; FAC-02. Critical. Approvals B-D.

Objective and method: For FWT-02.01, verify one Dell Precision 5820 Proxmox VE host, one separate physical HP OPNsense firewall and exactly three workload virtual machines (VMs). Match Management, Corporate (DC1 and WIN1) and Restricted (APP1) to the private switch and bridge map. Verify DC1 and WIN1 each have 2 vCPU, 6 GiB RAM and 64 GiB disk. Verify APP1 has 2 vCPU, 4 GiB RAM and 32 GiB disk. Guest totals are **6 vCPU / 16 GiB RAM / 160 GiB guest disks**. Measure host and storage reserves and temporary restore capacity separately against the capacity budget. Assess HP capacity separately.

Verify FF-01 through FF-08. Workload bridges have physical paths to HP and carry no host address or routing role. HP alone routes between zones with default deny. Inspect effective rules, including automatic rules, network address translation (NAT), listeners and states. Verify scoped Windows host rules for same-zone FF-02 and independent APP1 host policy. Demonstrate named administrator access, supported multifactor authentication (MFA), Dell and HP console recovery, WIN1-to-APP1 HTTPS on TCP 443, an unlisted routed denial at a known-listening service and ordinary-user management denial.

Expected result and pass/fail criteria: Only approved source and service paths work. Default-deny routing and host policy prevent extra access. The measured ledger fits and both consoles remain available.

Second observation: Compare capacity records to host and storage views. Match allowed and denied sessions to effective HP, management or host rules, logs and states. Confirm ordinary-user management denial before login. Verify console recovery and rollback using the network test procedure.

Record	Value
Actual result	
Evidence reference	
Operator / date / version	
Verdict	NOT TESTED

1.3. FWT-03 - Directory, six application cases and app revocation

Scope: FWR-03; FSC-03; FAC-03. Critical. Approvals E/H and relevant endpoint scope.

Objective and method: Verify isolated ad.lab.test, DC1 directory and DNS health, Group Policy and standard WIN1 logon and name resolution. Verify the three standard users ava, eli and uma. LabReaders contains ava and eli, LabMaintainers contains eli and LabAdmins contains the separate privileged administrator only. Check effective privileges. Run C01-C06 with valid application credentials distinct from Active Directory (AD) passwords. Compare manually mapped Apache roles to AD. Under approved scope, remove eli from Apache and AD LabMaintainers and force server requests from the existing authenticated browser and a fresh context. Record both changes, cache treatment and elapsed time.

Expected result and pass/fail criteria: All six outcomes match the table. After both changes, maintenance requests deny in both contexts and eli retains report access. Apache enforces its own roles independently of AD.

Second observation: Compare Windows logon evidence to directory membership and policy. Match the requests to Apache authorization logs and effective roles. Compare change and denial times with a separate clock. Follow the revocation and recovery procedure.

Record	Value
Actual result	
Evidence reference	
Operator / date / version	
Verdict	NOT TESTED

1.4. FWT-04 - Endpoint baseline and least privilege

Scope: FWR-04; FSC-04; FAC-04. Critical for privilege/bypass. Approval F.

Objective and method: Verify supported Windows/Linux builds and recorded updates. On DC1 and WIN1, inspect Microsoft Defender, Windows firewall profiles, effective Group Policy and audit settings, and standard versus administrator rights. On APP1, inspect default-deny input and forwarding rules, disabled IPv4 and IPv6 forwarding, and rule persistence and console recovery. Verify one zone NIC per guest, with only APP1's approved overlay exception. Check listeners and run one harmless administrator-only action as a standard user and as the approved administrator.

Expected result and pass/fail criteria: Standard users are denied and the approved administrator succeeds. Protections and audit settings are effective. Windows host policy limits same-zone traffic. APP1 host policy limits local and overlay access independently of HP's routed enforcement. No unapproved profiles, listeners, forwarding or bypass adapters are present.

Second observation: Match effective policy, services and rules to the standard-user denial and administrator control. Compare APP1 rules after an approved reboot. Pair the approved HTTPS permit and known-listening denial with the effective APP1 host rule and its log or counter. A routed block at HP establishes routed enforcement only. Keep the host check NOT TESTED if the listener, approved path or evidence is missing. Verify rollback from console if needed.

Record	Value
Actual result	
Evidence reference	
Operator / date / version	
Verdict	NOT TESTED

1.5. FWT-05 - HTTPS certificate trust and validity

Scope: FWR-05; FSC-05; FAC-05. Critical for false trust. Approval G.

Objective and method: Inspect one lab-only offline certificate authority (CA) with an encrypted private key and one APP1 server certificate. Verify the chain, CA constraints, server authentication purpose, subject alternative name (SAN) app.ad.lab.test, dates and remaining validity. On a functional lab client, observe chain rejection before importing the verified public root and normal HTTPS afterward. Use the approved lab store, existing clock and trust and rollback procedure.

Expected result and pass/fail criteria: The untrusted browser rejects the chain without bypass. The approved trusting browser opens the exact HTTPS name. The offline CA and APP1 keys remain protected. Trust stays on approved lab clients. Record that the lab has no certificate-revocation service.

Second observation: Compare chain and trust-store inspection with the actual rejected and successful browser handshakes.

Record	Value
Actual result	
Evidence reference	
Operator / date / version	
Verdict	NOT TESTED

1.6. FWT-06 - Tailscale one-resource access and revocation

Scope: FWR-06; FSC-06; FAC-06. Critical. Approval I plus isolated egress.

Objective and method: Verify three layers. Physical HP OPNsense restricts the underlying routed transport and independently isolated egress. Tailscale restricts identity, device and grant in the separate lab-only network (tailnet). APP1 host rules restrict overlay input and forwarding, and Apache enforces application roles. Verify supported MFA and recovery, enrollment of APP1 and one approved existing client, exact APP1 TCP 443 grant, additive grants and tag owners, overlay name mapping and absence of a direct client route to APP1. Verify subnet routing, exit nodes, Tailscale SSH, Funnel, Serve and sharing are off.

Demonstrate approved HTTPS with application roles, unauthorized identity denial and denial at a known-listening wrong port. Use a known-listening lab-owned mock for any required wrong-resource check. Keep the grant on TCP 443. Confirm the approved context works again, remove its grant and exact device authorization, then force network requests from the existing and a fresh session. Record cache or connection-state handling and observed time to each denial. Follow the remote verification procedure.

Expected result and pass/fail criteria: The approved client reaches only app.ad.lab.test HTTPS. Unauthorized identity, wrong port or resource and both revoked sessions are denied. DC1, WIN1, Proxmox and OPNsense are excluded. Production networks, identities and credentials stay separate. Missing safe egress leaves the test NOT TESTED.

Second observation: Match actual requests to effective grants, device state, APP1 host rules and counters, and Apache logs. Identify the control that enforced each denial. Use HP policy and logs for transport only. An unattributed denial remains NOT TESTED.

Record	Value
Actual result	
Evidence reference	
Operator / date / version	
Verdict	NOT TESTED

1.7. FWT-07 - Five events and one denied-access investigation

Scope: FWR-07; FSC-07; FAC-07. Approval J.

Objective and method: Record E01 directory authentication success and E02 directory authentication failure from DC1 Windows Security, E03 application access allowed and E04 application access denied from APP1 Apache, and E05 firewall access denied from physical HP OPNsense. Use valid application credentials for E04. Verify effective DC1 auditing and match the online authentication to the actual Kerberos result (for example 4768 or 4771). Check lockout margin and make only one safe wrong-password attempt. Compare source and observer UTC times. Investigate one denial with the working allowed control and event-time policy. Follow the event procedures.

Expected result and pass/fail criteria: All five distinct categories are searchable and attributable. Any approved two-source alternative must cover all five. Verify log access and rotation. The investigation identifies the request, the enforcing rule or role and the evidence for the decision.

Second observation: Compare each private original with the observed action and the effective audit, firewall or group policy. Keep raw logs in private custody.

Record	Value
Actual result	
Evidence reference	
Operator / date / version	
Verdict	NOT TESTED

1.8. FWT-08 - One automation and safe repetition

Scope: FWR-08; FSC-08; FAC-08. Approval L automation portion.

Objective and method: Review one local WIN1 disk-capacity summary. Verify the target/domain and private output-path guards. As a standard user, run it locally twice. Test invalid target and invalid path rejection separately. Compare output with the operating system storage view and inspect before/after files, accounts, network and system settings.

Expected result and pass/fail criteria: Both runs report accurate capacity. Only the intended private summary can change. Both invalid inputs are rejected without a write. Time and free space may vary. Keep the operation local and manual and keep credentials and private inventory out of Git.

Second observation: Compare disk values independently in the operating system. Verify before/after state for both successful runs and both rejections.

Record	Value
Actual result	
Evidence reference	
Operator / date / version	
Verdict	NOT TESTED

1.9. FWT-09 - One encrypted backup and isolated restore

Scope: FWR-09; FSC-09; FAC-09. Critical. Approval L recovery portion.

Objective and method: Operational restore remains **BLOCKED** until the owner approves the encrypted external-storage backend and recovery procedure as well as the exact isolated physical path, disconnection and rollback checklist. Follow the private recovery prerequisites. Verify original APP1 is stopped before backup and stays off through the drill. Verify one encrypted off-compute APP1 full backup on approved external storage with separate key custody. Record its age and coverage of pages, configuration, hashed application accounts, roles, server key, leaf and public root. Protect the sole backup.

Restore to an approved unused temporary VM ID. Before boot, disconnect every restored NIC and disable autostart. Verify copied Tailscale is inactive and disabled. Verify file hashes and content against the preserved manifest before attachment. Connect only the approved isolated WIN1-to-restored-APP1 path through physical HP OPNsense. Exclude upstream and nonparticipants. Use only approved narrow temporary client and firewall settings. With valid ava credentials over trusted HTTPS, verify report access and authenticated maintenance denial. Measure actual time from restore confirmation until integrity and usable HTTPS are verified.

Expected result and pass/fail criteria: The copy matches the manifest and the approved HTTPS allow and deny decisions. Preserve original APP1 and the sole backup without connecting duplicate identities. Record application recovery time and AD, CA, host and physical-firewall recovery exclusions. Same-disk snapshots do not qualify.

Second observation: Compare restore output with a separate clock, manifest and role requests, and match the routed path and application decisions to HP, host and Apache evidence. Verify the copy is disconnected and stopped before rolling back temporary settings. Verify original state and encrypted off-compute custody after cleanup.

Record	Value
Actual result	
Evidence reference	
Operator / date / version	
Verdict	NOT TESTED

1.10. FWT-10 - Evidence, publication and final handover

Scope: FWR-10; FSC-10; FAC-10. Critical for disclosure/false claims. Approvals K/L closeout.

Objective and method: Review all mandatory subchecks, mapped requirements and controls, evidence, defects and final claims. Complete the five files below and apply the single 100-point rubric. Review the full proposed public set, metadata, staged diff and new history. Run the documentation and publication checks, including finalized-report, links, Office, PDF/rebuild, regressions and whitespace. Verify the pull request (PR), its final-head continuous integration (CI) results, merge and synchronized main.

Use private working copies of the released templates.

- `01-Lab-Environment-and-Architecture.xlsx`
- `02-Identity-and-Zero-Trust-Implementation.docx`
- `03-Security-Monitoring-and-Testing.xlsx`
- `04-Troubleshooting-and-Lessons.xlsx`
- `05-Final-Project-Submission.docx`

Expected result and pass/fail criteria: All mandatory results have evidence and safety issues are resolved. Keep private originals, raw logs, credentials, keys and backups outside Git. Submit reviewed public-safe artifacts. Record the actual engineering verifier and evidence cutoff. Owner UAT stays PENDING until explicit acceptance is recorded separately.

Second observation: Cross-check claims against the evidence index and compare local Git with live GitHub. Verify the actual lab records and owner decision separately. Blank templates, reports and CI supply documentation evidence only.

Record	Value
Actual result	
Evidence reference	
Operator / date / version	
Verdict	NOT TESTED

2. Six application access cases

These six cases are subchecks of FWT-03, not extra test IDs. Three permit and three deny outcomes use authenticated synthetic users on the same named HTTPS application. The maintenance path is a synthetic instruction page, not shell access.

Table 1. Six application access cases

Case	User / role	Resource	Expected
C01	ava / LabReaders	/reports/	Allow
C02	ava / no maintenance role	/maintenance/	Deny
C03	eli / LabReaders	/reports/	Allow
C04	eli / LabMaintainers	/maintenance/	Allow
C05	uma / no reader role	/reports/	Deny
C06	uma / no maintenance role	/maintenance/	Deny

The separate revocation checks verify eli's existing and fresh requests after the maintenance role is removed. FWT-02 covers management and segmentation. FWT-06 covers remote access and revocation.

3. Coverage index

Each requirement maps to an architecture component or flow, security control, focused test, acceptance criterion and deliverable. File numbers refer to the five filenames in FWT-10.

Table 2. Coverage index

Requirement	Architecture component / flow	Security control	Test	Acceptance	File
FWR-01	Physical boundary; FF-07/08	FSC-01	FWT-01	FAC-01	01
FWR-02	Dell Proxmox, physical HP OPNsense, three workload VMs and three zones. FF-01 through FF-08	FSC-02	FWT-02	FAC-02	01
FWR-03	DC1/WIN1/APP1 roles; FF-02/03	FSC-03	FWT-03	FAC-03	02
FWR-04	DC1, WIN1 and APP1 host policy	FSC-04	FWT-04	FAC-04	02
FWR-05	Offline CA/APP1 HTTPS; FF-03	FSC-05	FWT-05	FAC-05	02
FWR-06	APP1/client overlay; FF-06/07	FSC-06	FWT-06	FAC-06	02
FWR-07	Physical HP OPNsense, DC1 Security and APP1 Apache logs	FSC-07	FWT-07	FAC-07	03
FWR-08	WIN1 local capacity operation	FSC-08	FWT-08	FAC-08	03
FWR-09	Encrypted off-compute APP1 backup and isolated restore through HP	FSC-09	FWT-09	FAC-09	03
FWR-10	Private/public boundary and handover	FSC-10	FWT-10	FAC-10	03, 04, 05

The historical transition tables retain R01-R16 and T00-T20 with their historical evidence. Current tests require their own results.